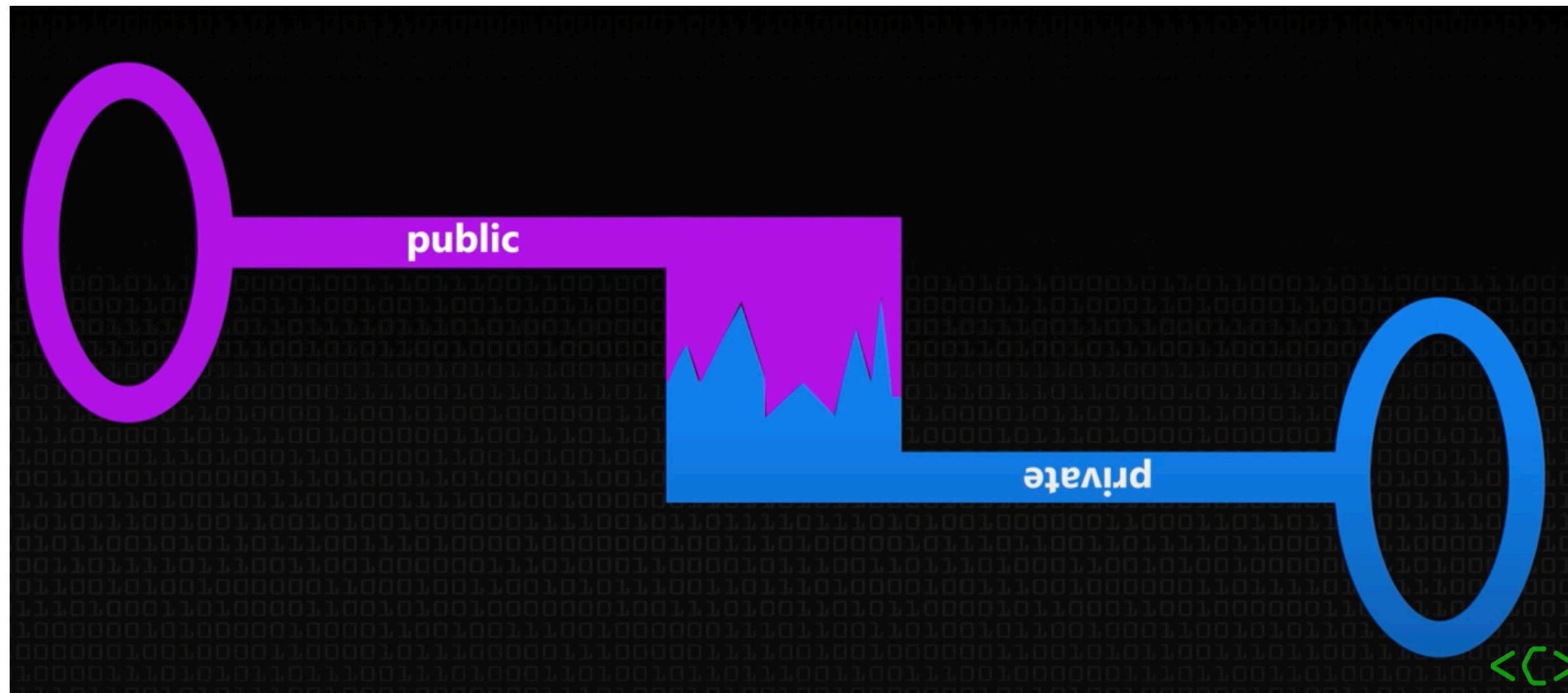


TLS (SSL)

Vsebina

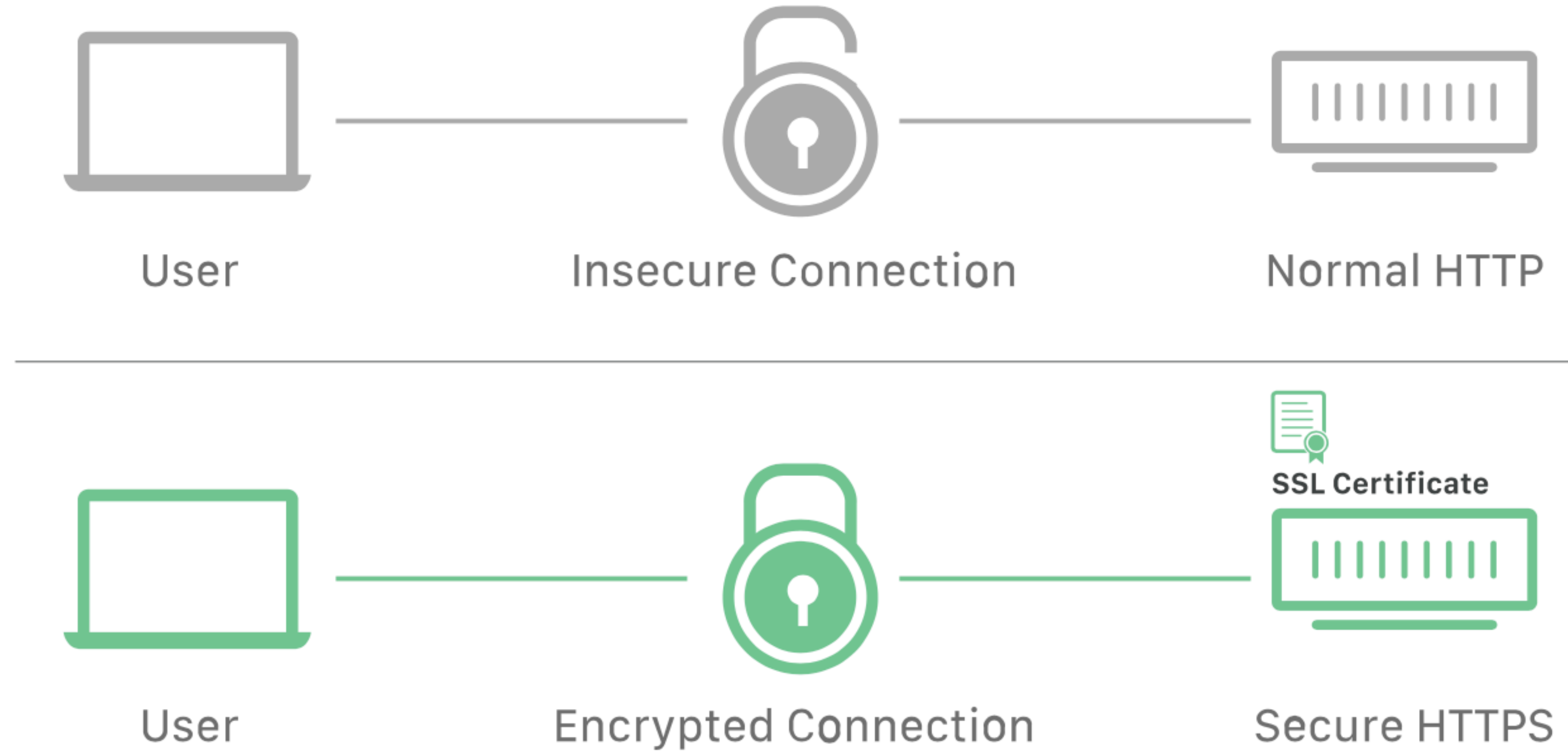
- SSL TLS?
- HTTPS
- Public - private key koncept
- Diffie - Hellman izmenjava ključev
- AKE - podpisovanje in izmenjava - hands on
- Hands-on HTTPS
- Quantum computing - breaking the code

Keys/certificates



HTTPS

HTTP vs HTTPS



SSL in TLS

Ali sta SSL in TLS ista stvar?

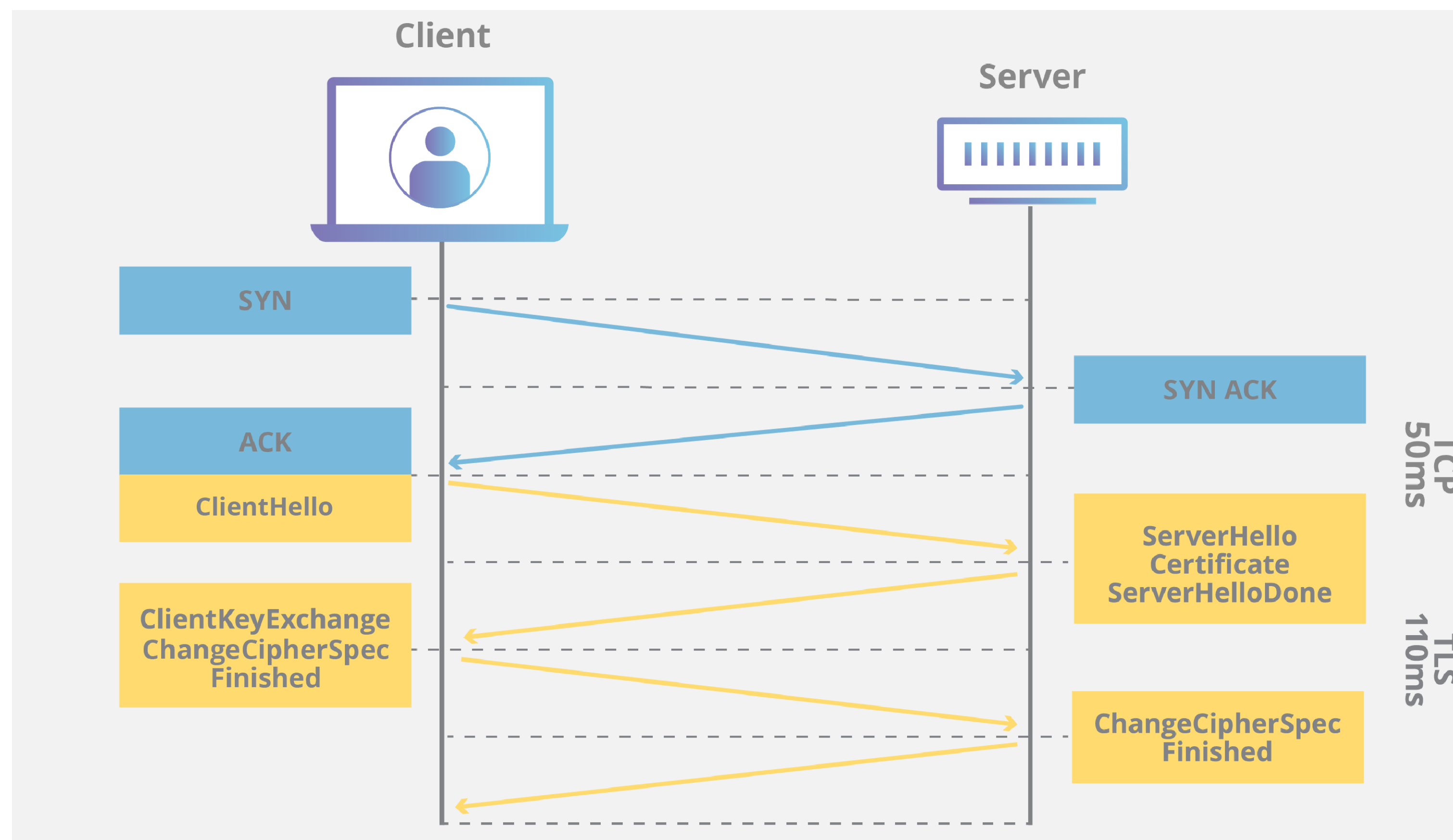
- SSL je neposredni predhodnik drugega protokola, imenovanega TLS (Transport Layer Security). Leta 1999 je Internet Engineering Task Force (IETF) predlagala posodobitev SSL. Ker je to posodobitev razvijal IETF in Netscape ni bil več vključen, je bilo ime spremenjeno v TLS. Razlike med končno različico SSL (3.0) in prvo različico TLS niso drastične; sprememba imena je bila uporabljena za označevanje spremembe lastništva.
- Ker sta tako tesno povezana, se izraza pogosto uporabljata zamenljivo in zamenjujeta. Nekateri ljudje še vedno uporabljajo SSL za sklicevanje na TLS, drugi uporabljajo izraz "šifriranje SSL/TLS", ker ima SSL še vedno veliko prepoznavnosti imen.

SSL in TLS

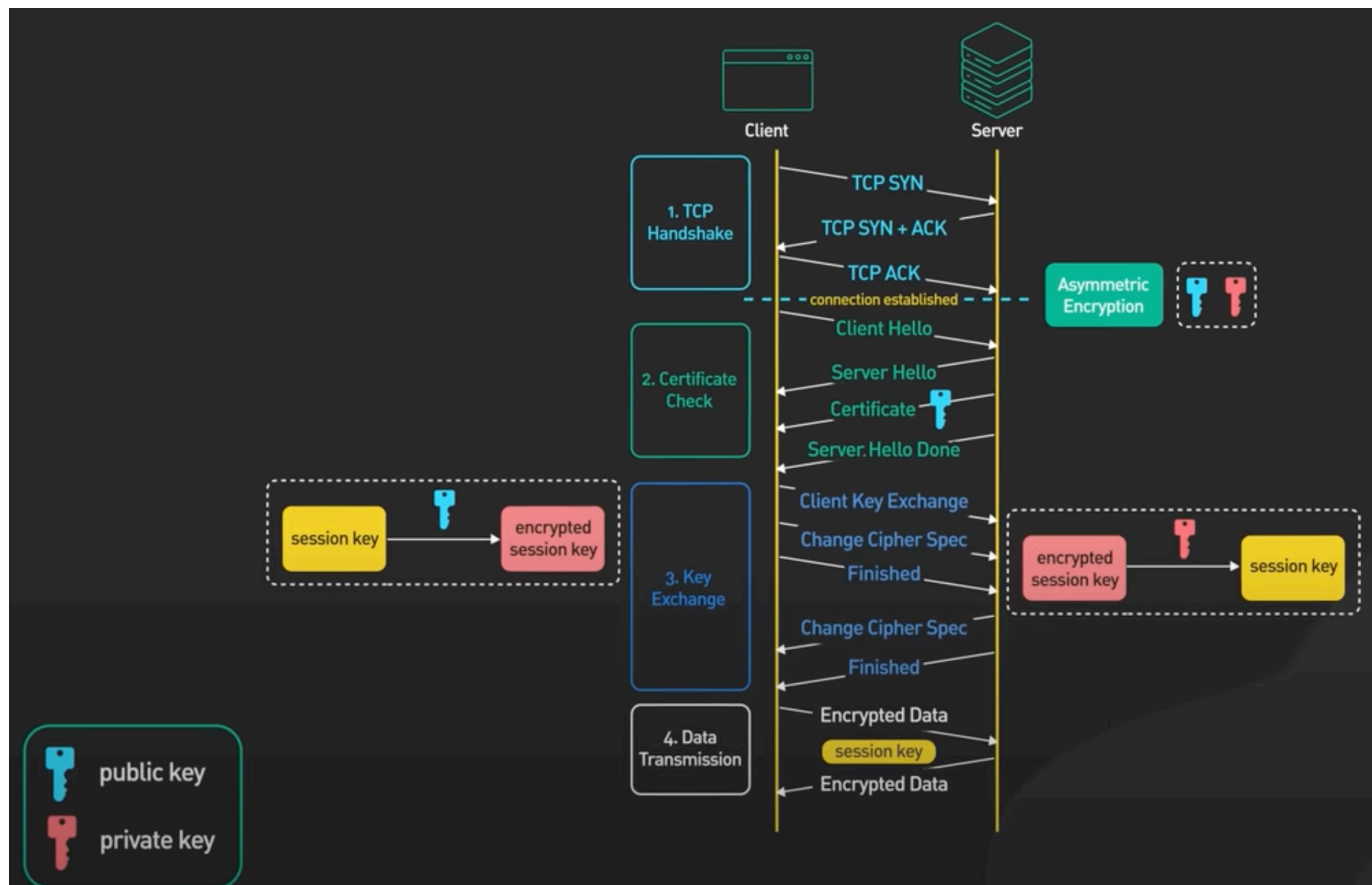
Je SSL še vedno posodobljen?

- SSL ni bil posodobljen od SSL 3.0 leta 1996 in se zdaj šteje za zastarelega. V protokolu SSL je znanih več ranljivosti in varnostni strokovnjaki priporočajo opustitev njegove uporabe. Pravzaprav večina sodobnih spletnih brskalnikov SSL sploh ne podpira več.
- TLS je najsodobnejši šifrirni protokol, ki se še vedno izvaja na spletu, čeprav ga veliko ljudi še vedno imenuje "šifriranje SSL". To je lahko vir zmede za nekoga, ki kupuje varnostne rešitve. Resnica je, da vsak prodajalec, ki danes ponuja "SSL", skoraj zagotovo zagotavlja zaščito TLS, ki je industrijski standard že več kot 20 let. Ker pa veliko ljudi še vedno išče "zaščito SSL", je izraz še vedno vidno prikazan na številnih straneh izdelkov.

Kako deluje TLS?

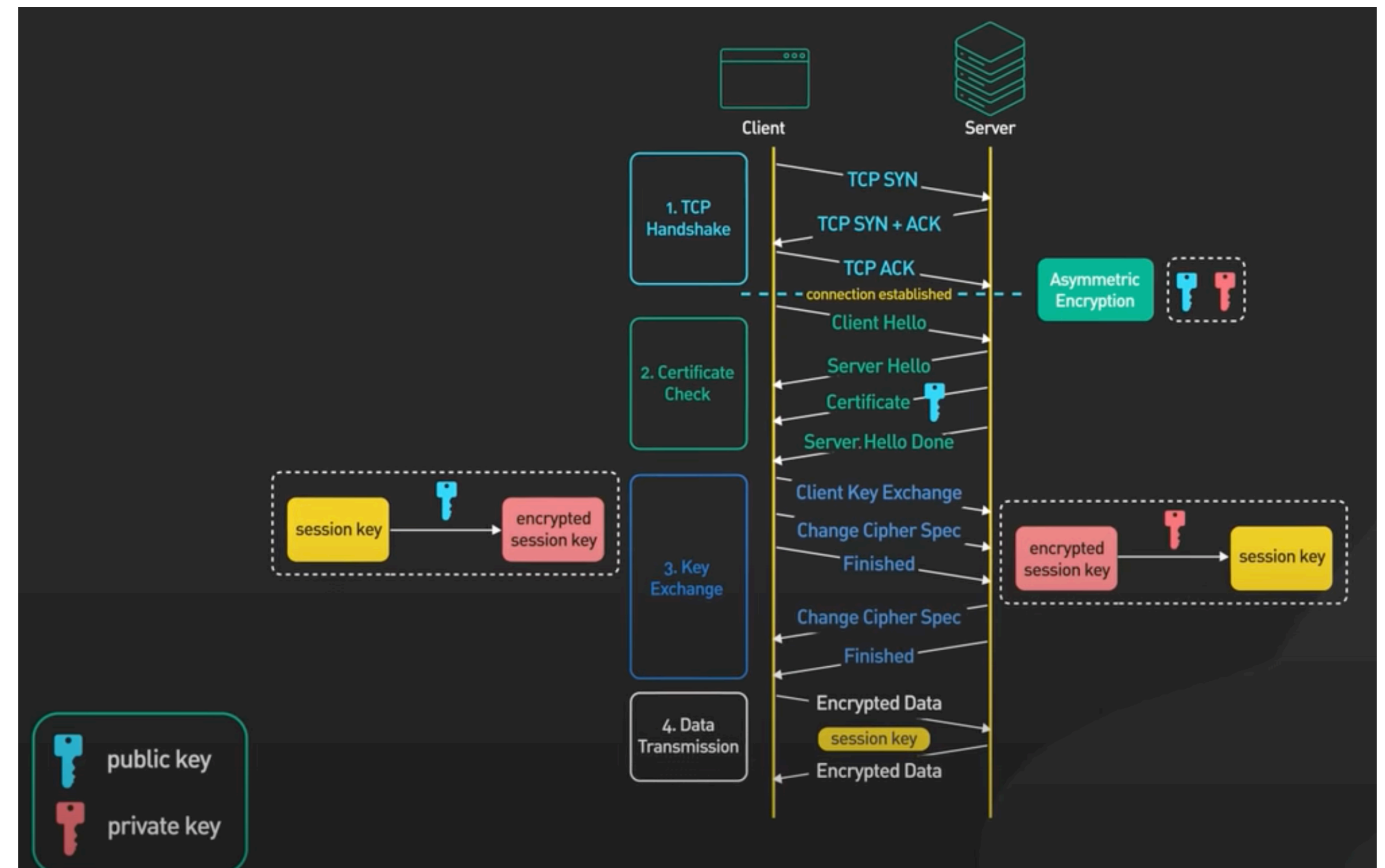


Kako deluje TLS?



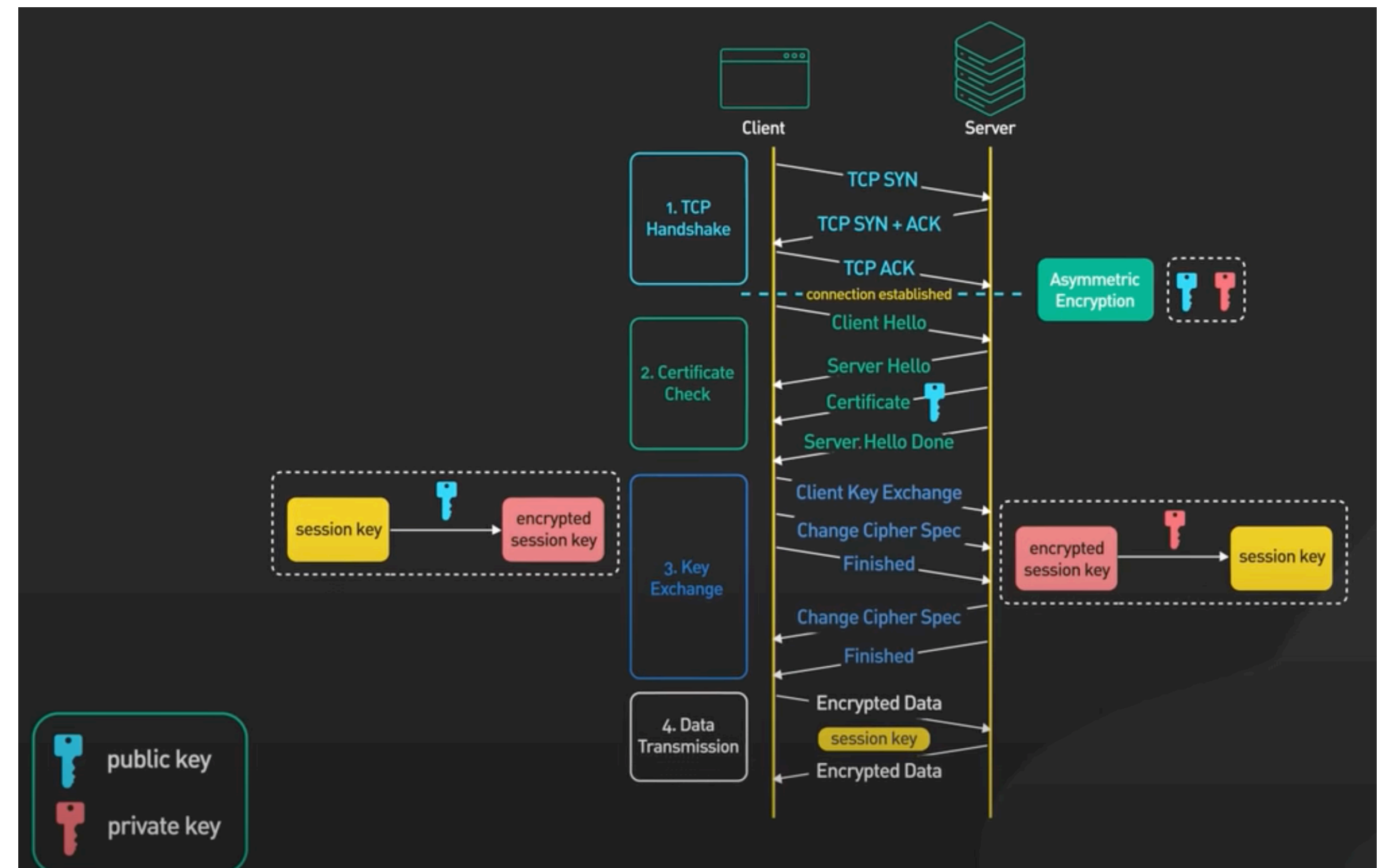
Kaj se zgodi med rokovanjem TLS?

- Med rokovanjem TLS bosta odjemalec in strežnik skupaj naredila naslednje:
 - Določita, katero različico TLS (TLS 1.0, 1.2, 1.3 itd.) bodo uporabljali
 - Odločita se, katere zbirke šifer bodo uporabili
 - Preverjanje identitete strežnika prek javnega ključa strežnika in digitalnega podpisa overitelja potrdil SSL
 - Ustvarita ključe seje za uporabo simetričnega šifriranja po končanem rokovanju



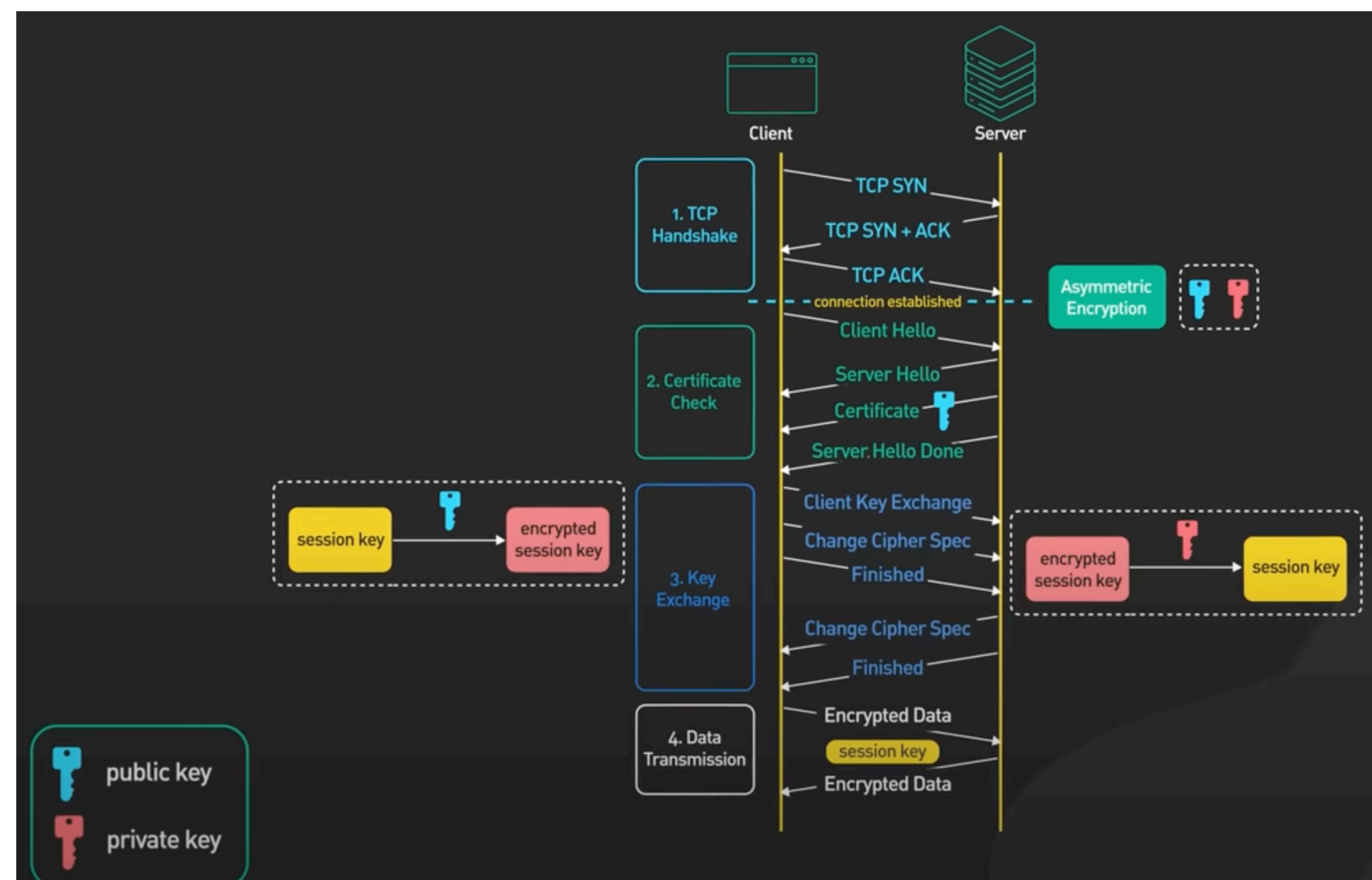
Kaj se zgodi med rokovanjem TLS?

- TLS rokovanja so niz datagramov ali sporočil, ki si jih izmenjujeta odjemalec in strežnik. Rokovanje TLS vključuje več korakov, saj si odjemalec in strežnik izmenjujeta informacije, potrebne za dokončanje rokovanja in omogočanje nadaljnjega pogovora. Gre približno takole:
 - Sporočilo '**Client Hello**': odjemalec sproži rokovanje tako, da strežniku pošlje sporočilo 'hellow'. Sporočilo bo vključevalo, katero različico TLS podpira odjemalec, podprte zbirke šifer in niz naključnih bajtov, znan kot "naključni odjemalec".
 - Sporočilo '**Server hello**': kot odgovor na pozdravno sporočilo odjemalca pošlje strežnik sporočilo, ki vsebuje potrdilo SSL strežnika, izbrano strežniško zbirko šifr in "naključno strežnika", drug naključni niz bajtov, ki jih ustvari strežnik.
 - **Avtentikacija**: odjemalec preveri potrdilo SSL strežnika pri overitelju potrdil, ki ga je izdal. To potrjuje, da je strežnik tisti, za katerega se predstavlja, in da je odjemalec v interakciji z dejanskim lastnikom domene.
 - **Predmaster secret**: odjemalec pošlje še en naključni niz bajtov, "premaster skrivnost". Premaster skrivnost je šifrirana z javnim ključem in jo lahko strežnik dešifrira samo z zasebnim ključem. (Odjemalec dobi javni ključ iz potrdila SSL strežnika.)



Kaj se zgodi med rokovanjem TLS?

- Uporabljen zasebni ključ: Strežnik dešifrira predhodno skrivnost.
- Ustvarjeni ključi seje: Tako odjemalec kot strežnik ustvarita ključe seje iz naključnih odjemalcev, naključnih strežnikov in premaster skrivnosti. Morali bi doseči enake rezultate.
- Odjemalec je pripravljen: odjemalec pošlje "končano" sporočilo, ki je šifrirano s ključem seje.
- Strežnik je pripravljen: strežnik pošlje "končano" sporočilo, šifrirano s ključem seje.
- Doseženo varno simetrično šifriranje: rokovanje je zaključeno in komunikacija se nadaljuje z uporabo ključev seje.



Diffie - Hellman - brez matematike

Alice



Public domain

g

n



Bob



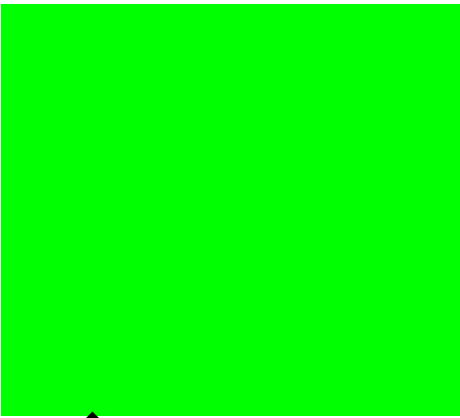
Diffie - Hellman - brez matematike

Alice

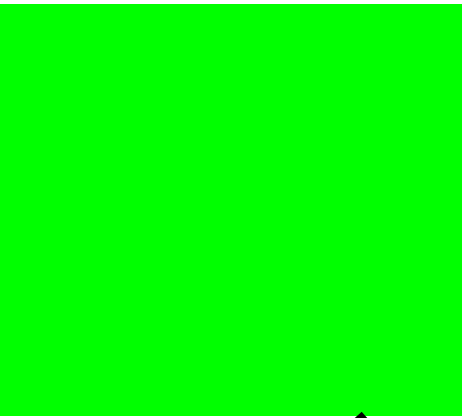


Public domain

g



n



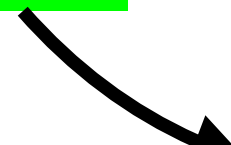
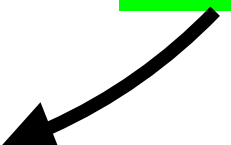
Bob



ag



bg



Diffie - Hellman - brez matematike

Alice



Public domain

g

n



Bob



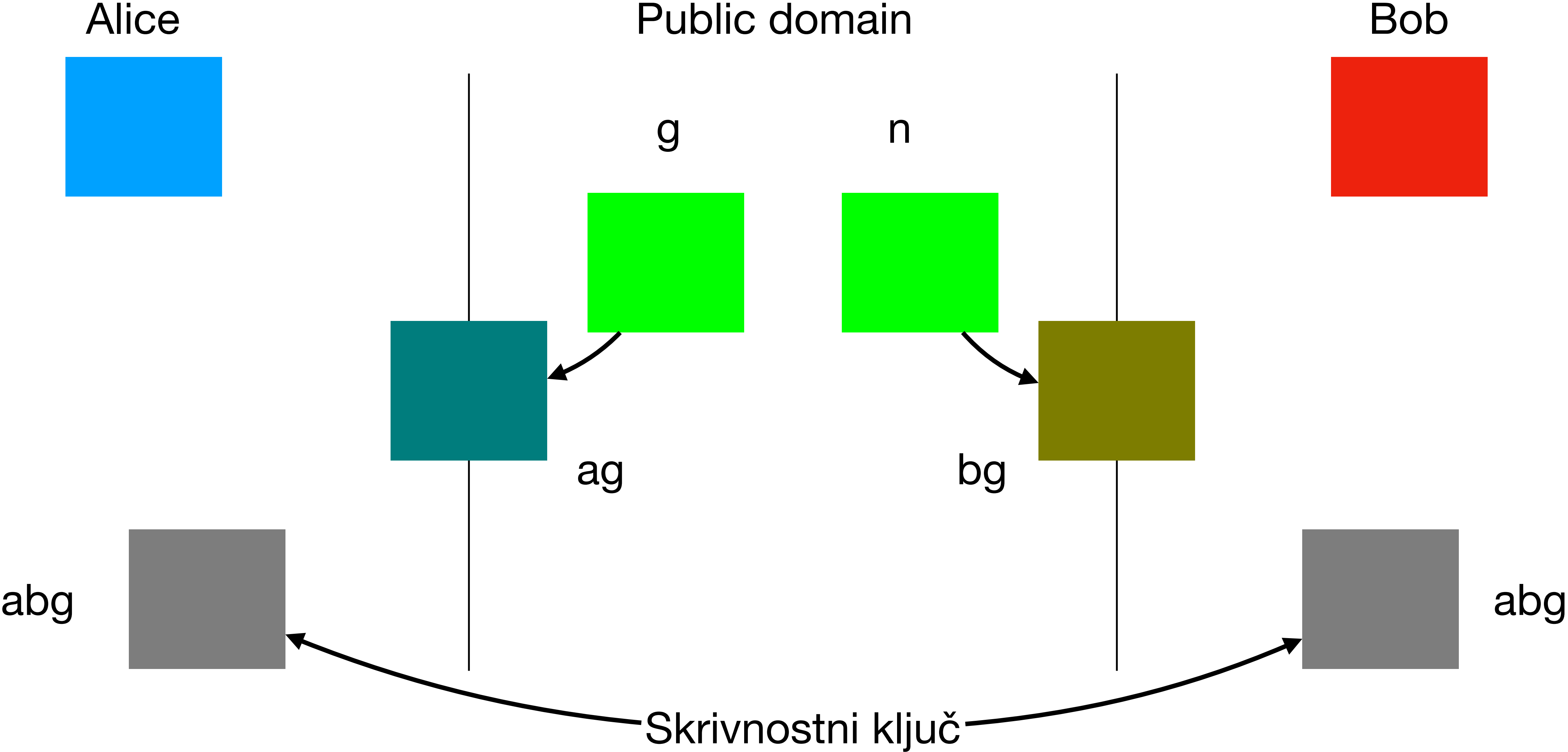
ag



bg



Diffie - Hellman - brez matematike



Diffie - Hellman - z matematiko

Alice



Public domain

g
Malo praštevilo

n
Veliko praštevilo
4000 bits

Bob



Diffie - Hellman - z matematiko

Alice



$$g^a \bmod n$$

Public domain

g
Malo praštevilo

n
Veliko praštevilo
4000 bits

Bob



Diffie - Hellman - z matematiko

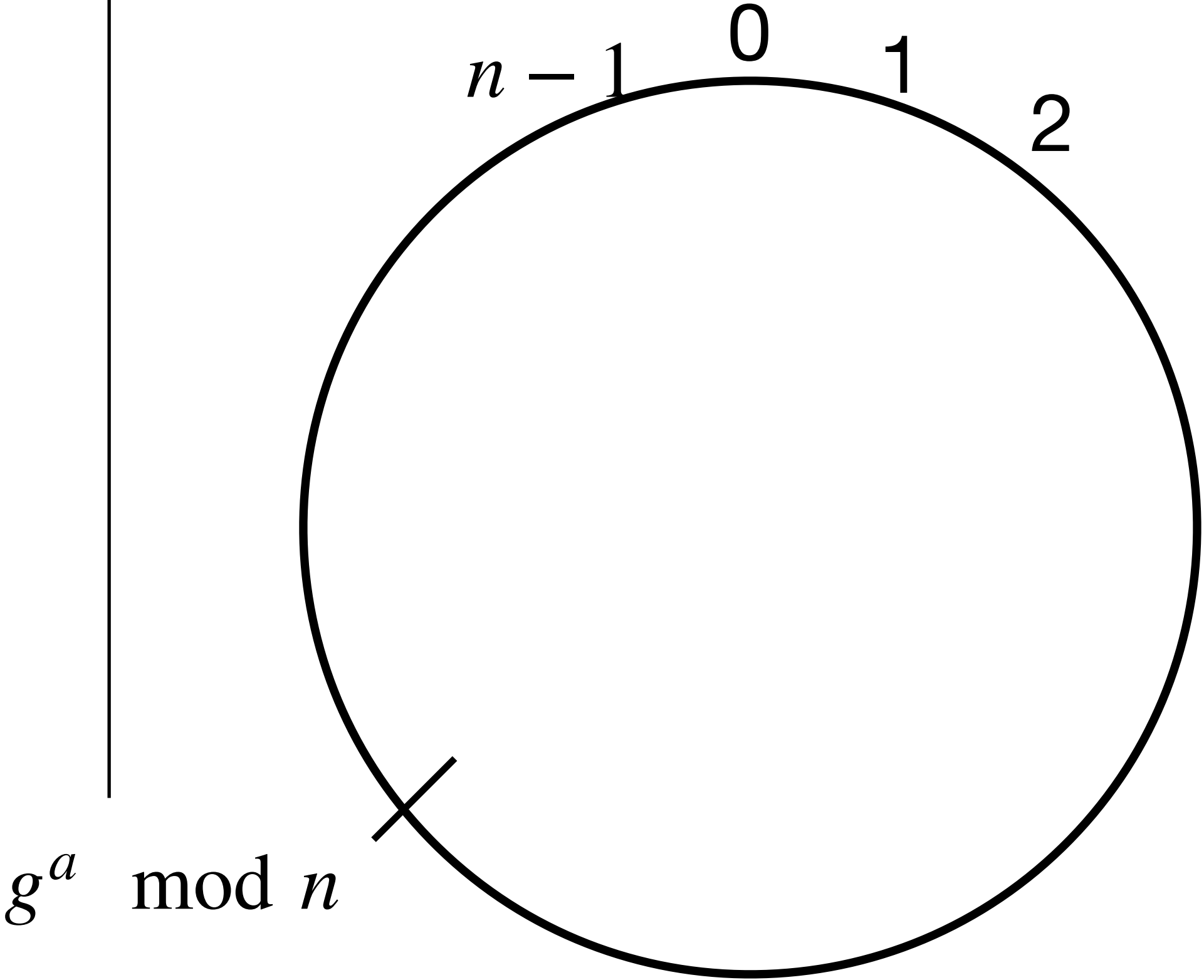
Alice



$g^a \bmod n$

Public domain

g Malo praštevilo
 n Veliko praštevilo
4000 bits



Bob



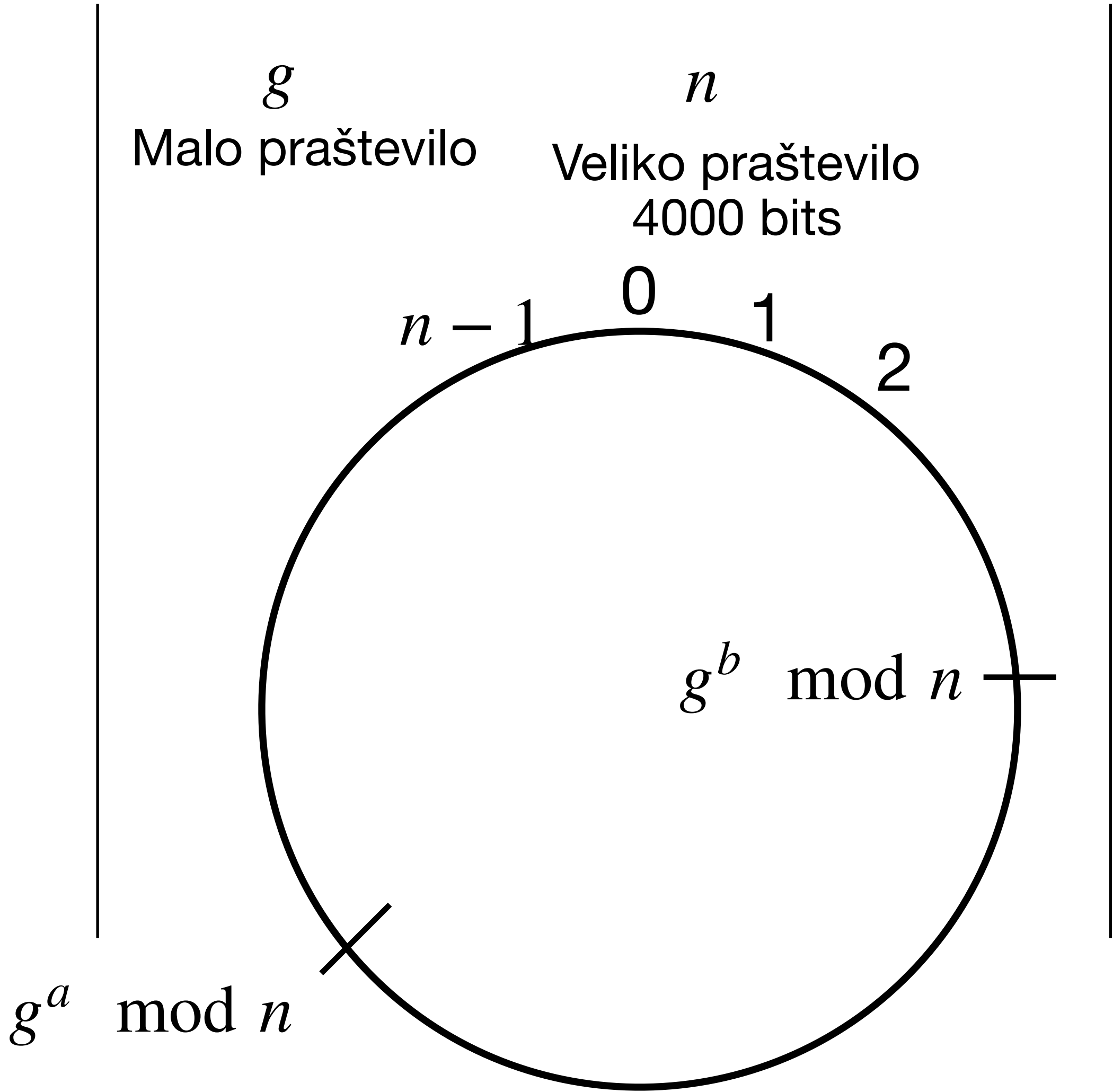
Diffie - Hellman - z matematiko

Alice



$$g^a \bmod n$$

Public domain



Bob



$$g^b \bmod n$$

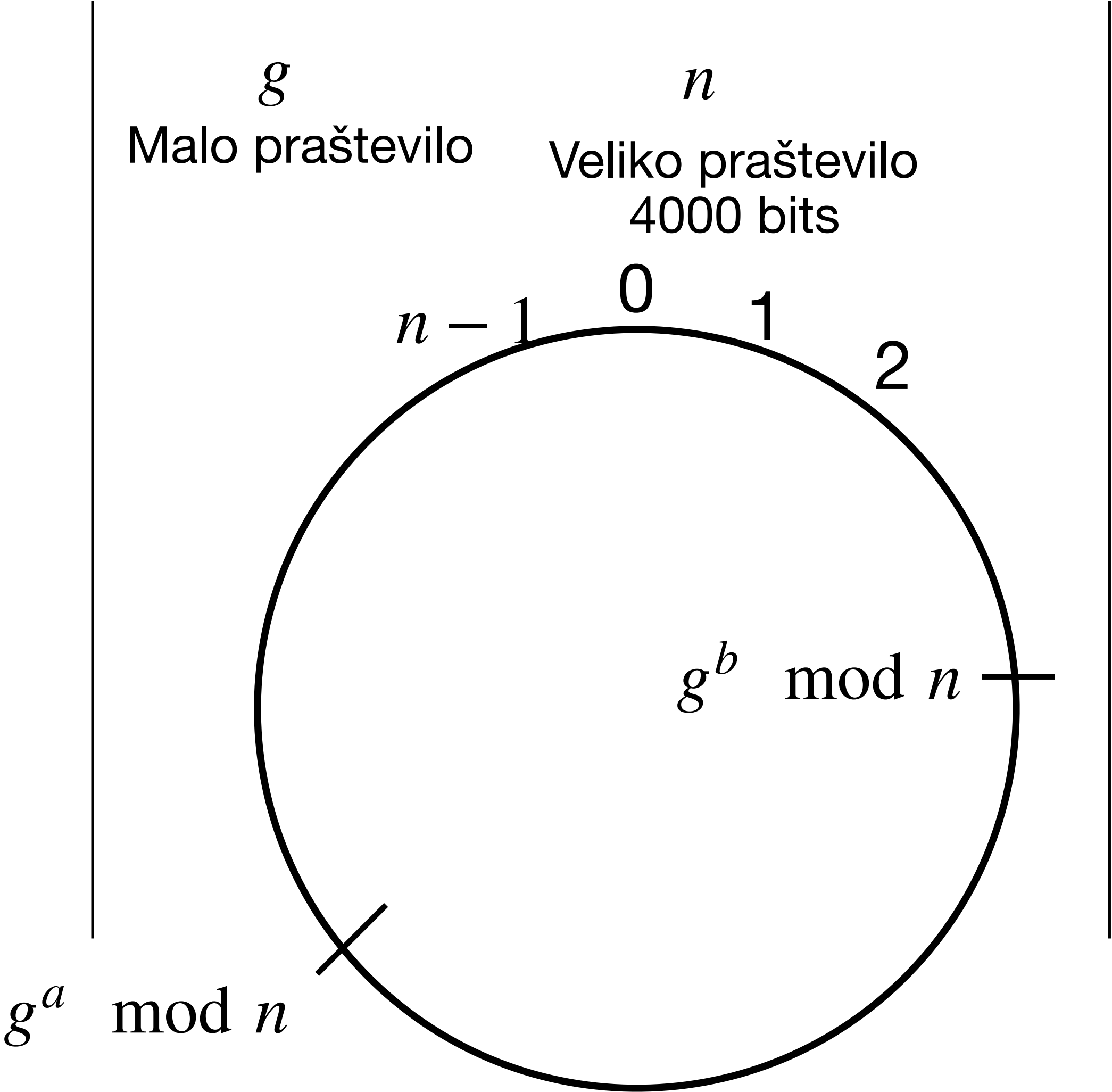
Diffie - Hellman - z matematiko

Alice



$$g^a \bmod n$$

Public domain



Bob



$$g^b \bmod n$$

Diffie - Hellman - z matematiko

Alice



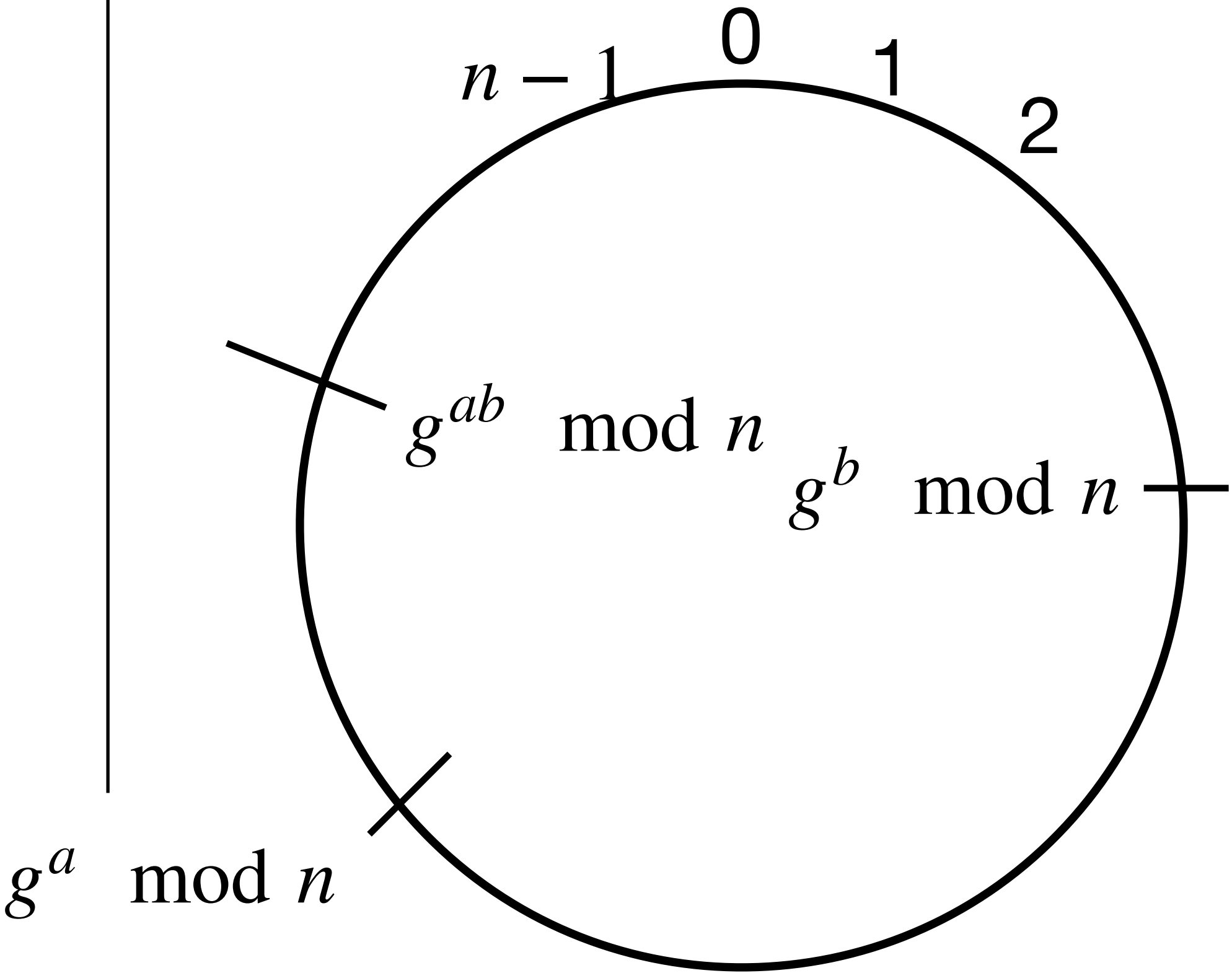
$$g^a \bmod n$$

$$(g^a)^b \bmod n$$

$$g^{ab} \bmod n$$

Public domain

g Malo praštevilo
 n Veliko praštevilo
4000 bits



Bob



$$g^b \bmod n$$

$$(g^b)^a \bmod n$$

$$g^{ab} \bmod n$$

Diffie - Hellman - Problem z middle man

Alice



$$g^a \bmod n$$

$$(g^a)^x \bmod n$$

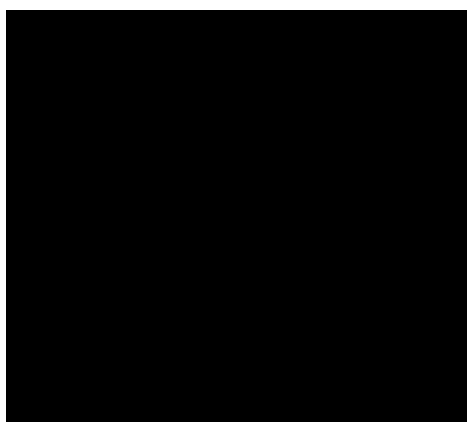
$$g^{ax} \bmod n$$

Public domain

$$g \quad n$$

$$g^x \bmod n$$

$$g^{ax} \bmod n$$



X

$$g^{bx} \bmod n$$

Bob



$$g^b \bmod n$$

$$(g^b)^x \bmod n$$

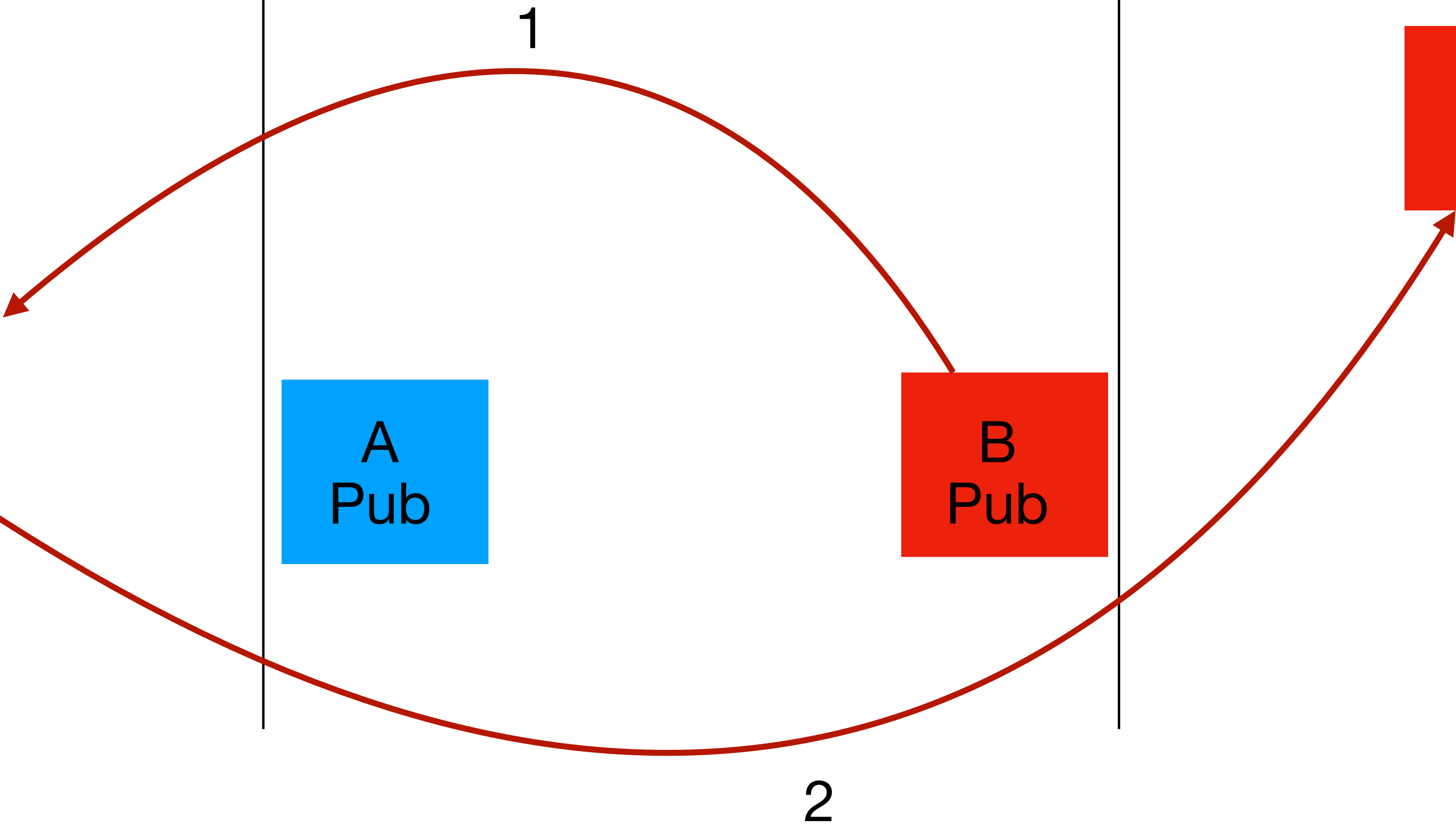
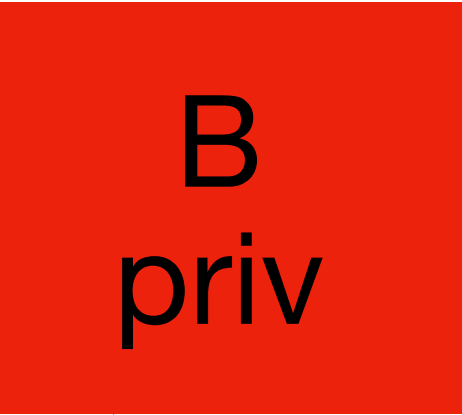
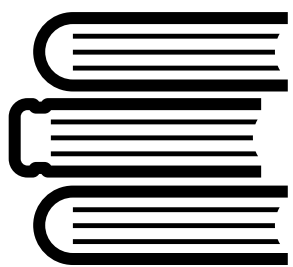
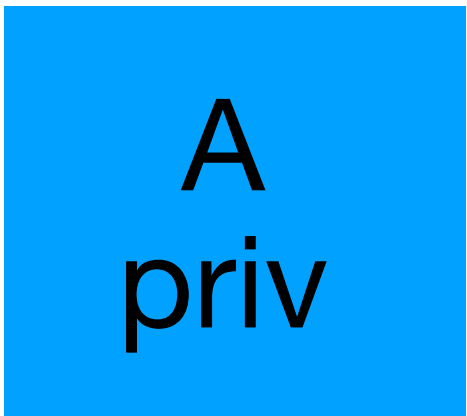
$$g^{bx} \bmod n$$

Private/Public keys

Alice

Public domain

Bob



Private/Public keys

- `openssl genrsa -aes128 -out alice_private.pem 1024`
- `openssl rsa -in alice_private.pem -pubout > alice_public.pem`

- `openssl genrsa -aes128 -out bob_private.pem 1024`
- `openssl rsa -in bob_private.pem -pubout > bob_public.pem`

Private/Public keys

- `echo "vim or emacs ?" > top_secret.txt`
- `openssl rsautl -encrypt -inkey bob_public.pem -pubin -in top_secret.txt -out top_secret.enc`
- `openssl rsautl -decrypt -inkey bob_private.pem -in top_secret.enc`

A vemo kdo je poslal sporočilo?

- Public ključ je dostopen vsem
- Izbira public private je arbitrary
- Lahko naredimo enkripcijo s privatnim ključem

Private/Public keys

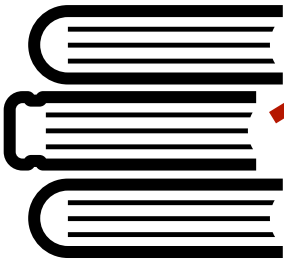
Alice

Public domain

Bob

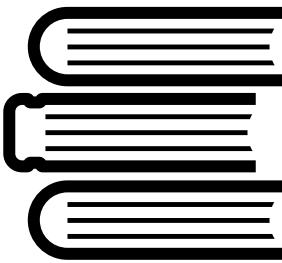
A
priv

B
priv



A
Pub

B
Pub

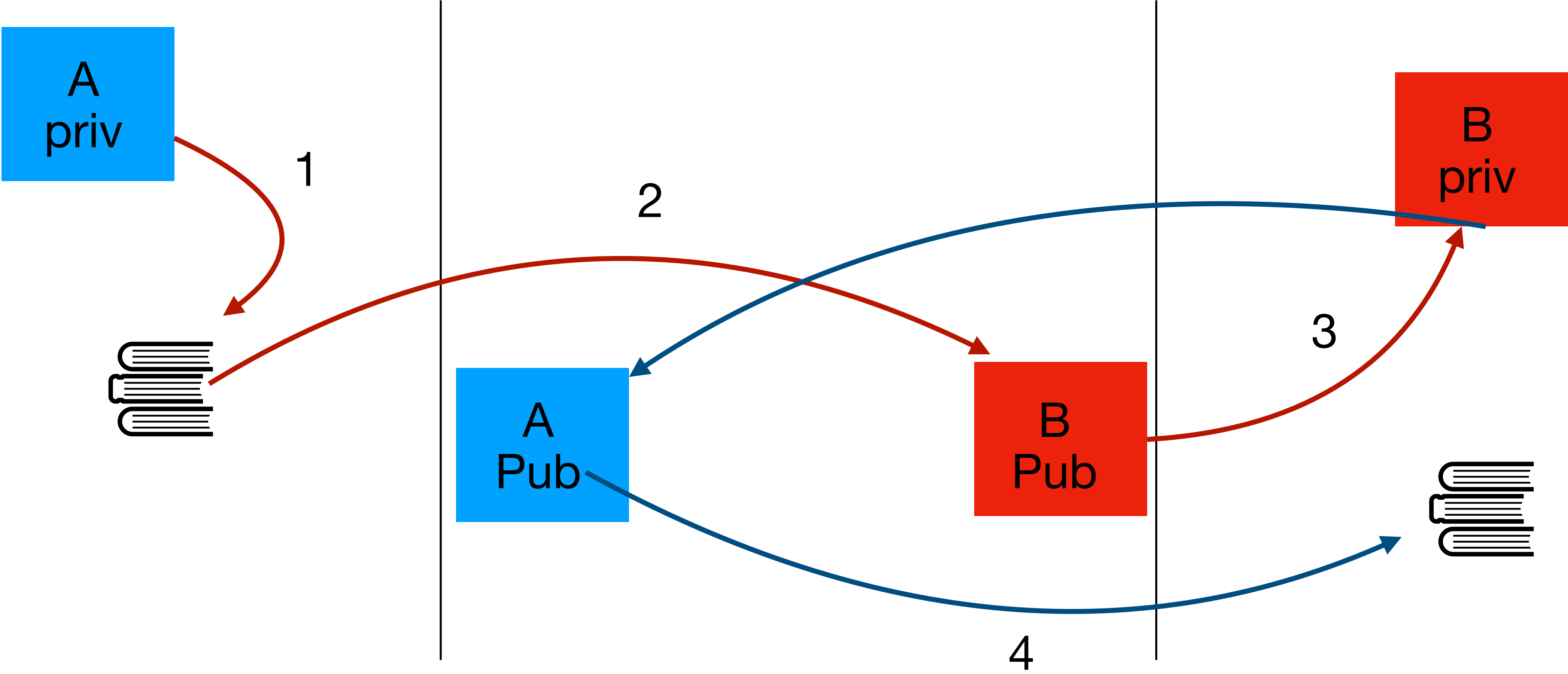


1

2

3

4



Signature

- `openssl dgst -sign alice_private.pem -keyform PEM -sha256 -out signature.sign -binary top_secret.txt`
- `openssl dgst -verify alice_public.pem -keyform PEM -sha256 -signature signature.sign -binary top_secret.txt`

RSA + ephemeral Diffie-Hellman

- Če uporabljamo samo RSA
 - En crack lahko dekriptira vso zgodovino
 - Prepočasno ker je nesimetrična
- Ephemeral (minljivo) DH
 - Velja le za določeno sejo (session)
 - Preprost in učinkovit način, da določimo kratkotrajne ključe za simetrično enkripcijo

DH

Alice

$$g^a \bmod n$$

Public domain

$$g \qquad n$$

Bob

$$g^b \bmod n$$

$$g^c \bmod n$$

$$g^d \bmod n$$

C

$$g^c \bmod n$$

D

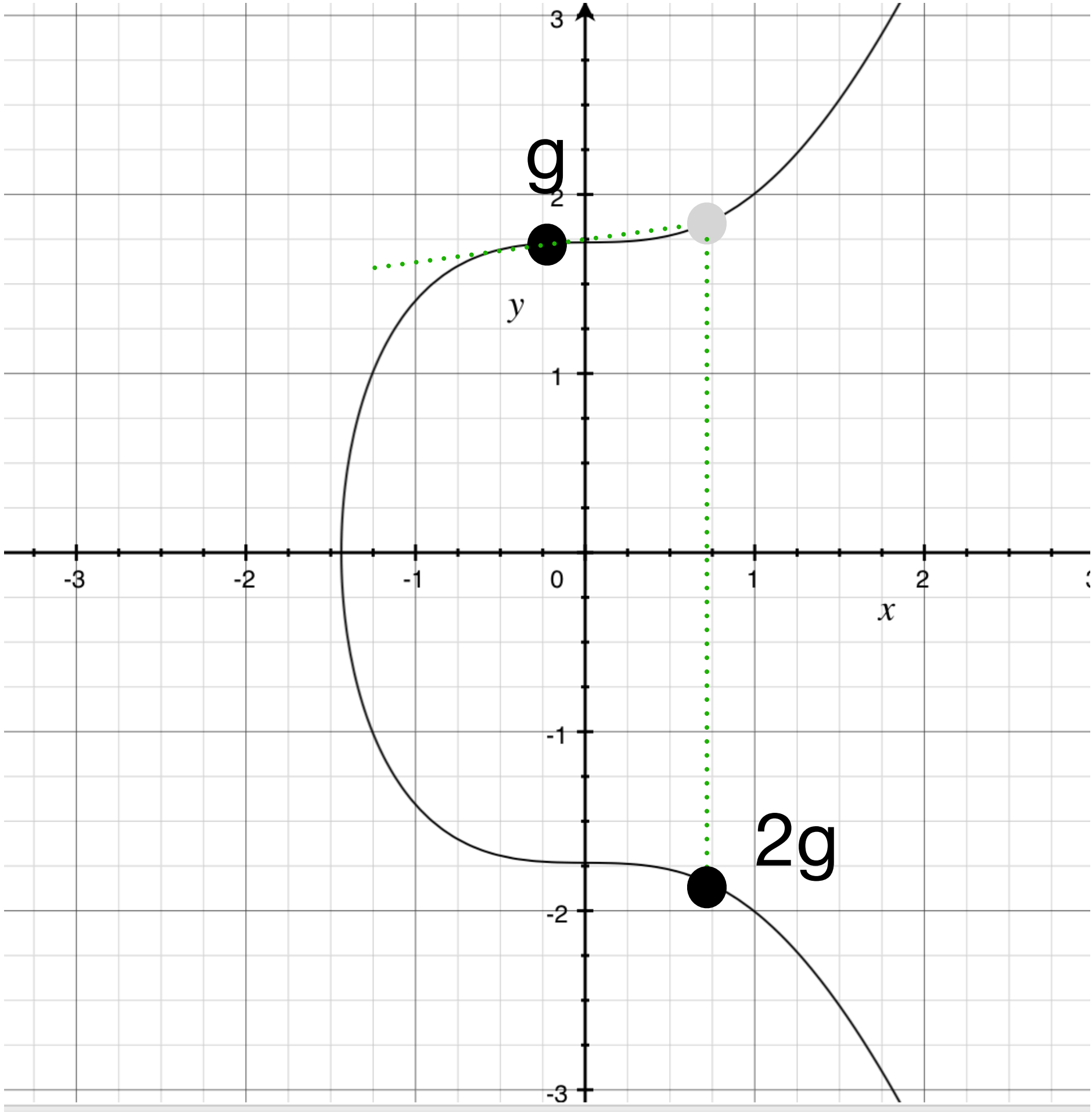
$$g^d \bmod n$$

Elliptic curves

Alice

$g^a \bmod n$

$y^2 = x^3 + ax + b$

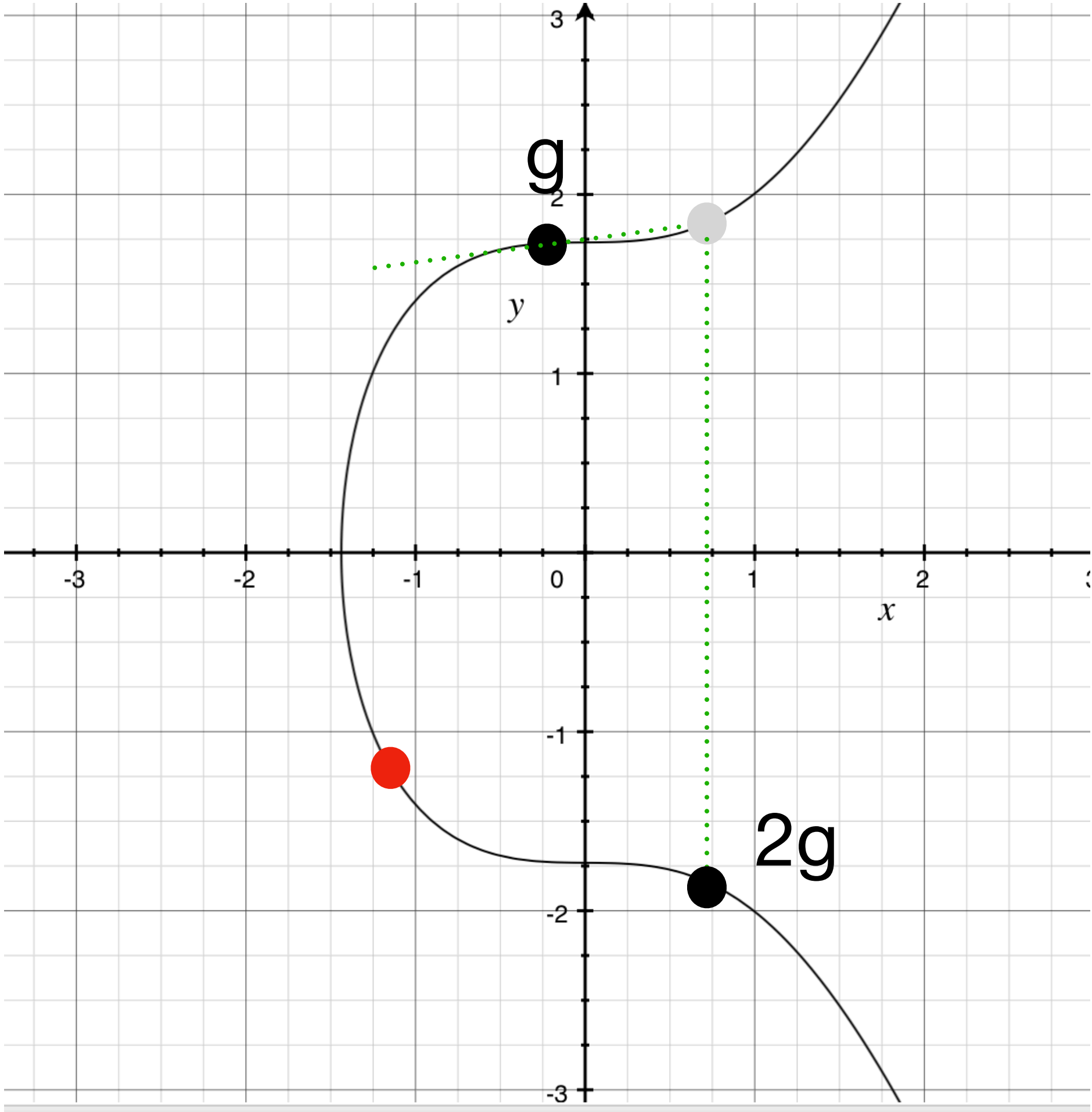


Elliptic curves

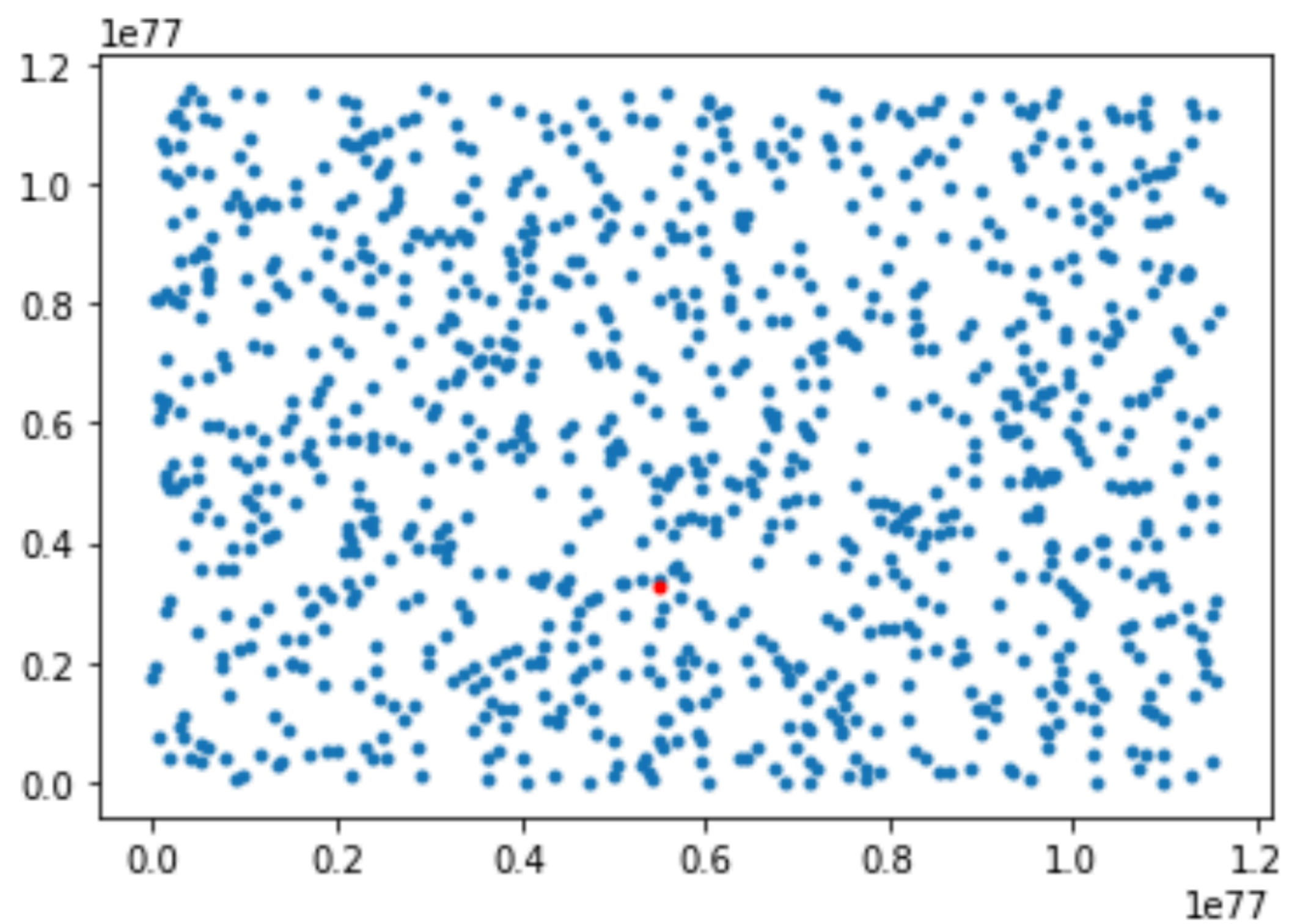
Alice

$g^a \bmod n$

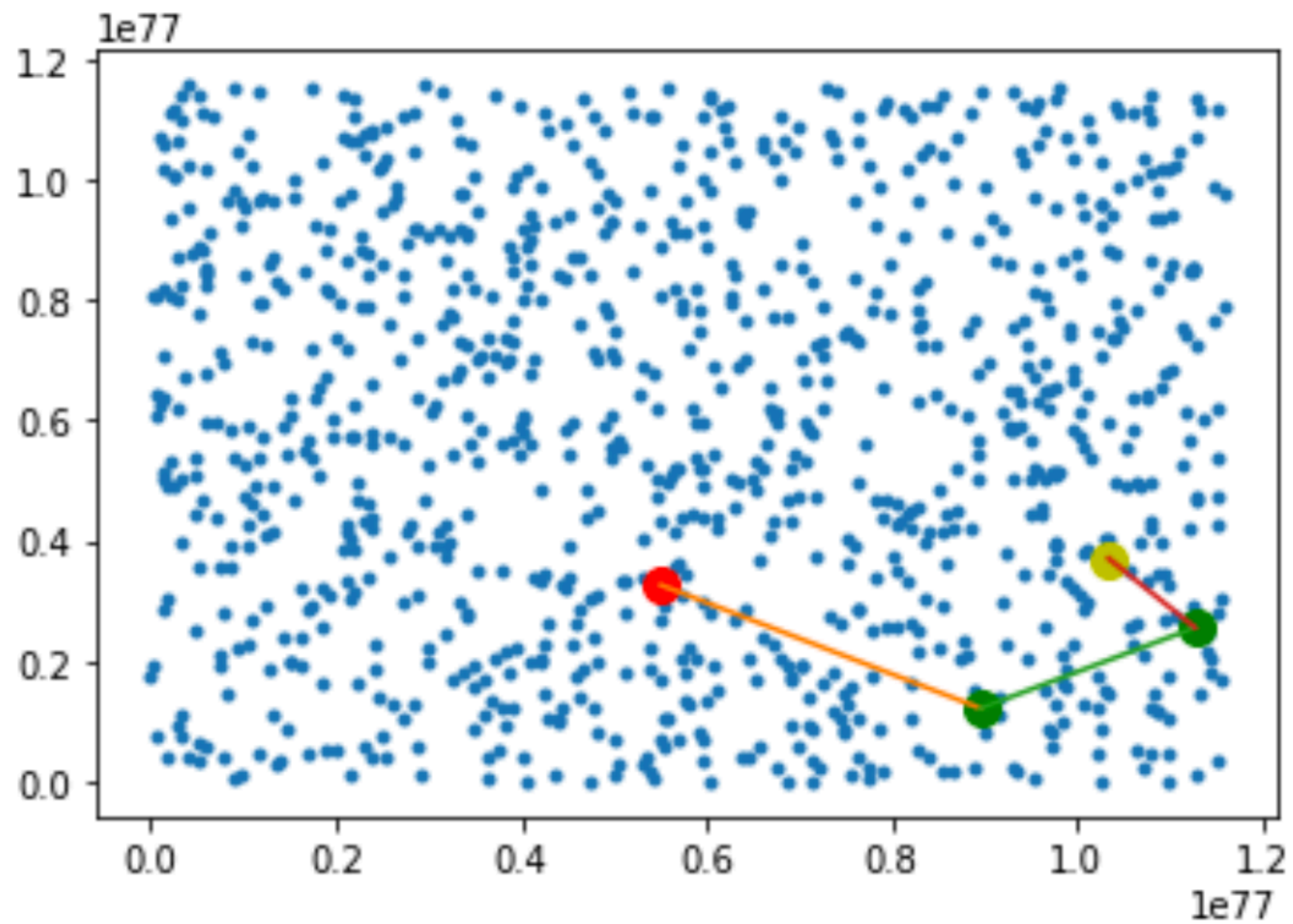
$y^2 = x^3 + ax + b$



Začetna G

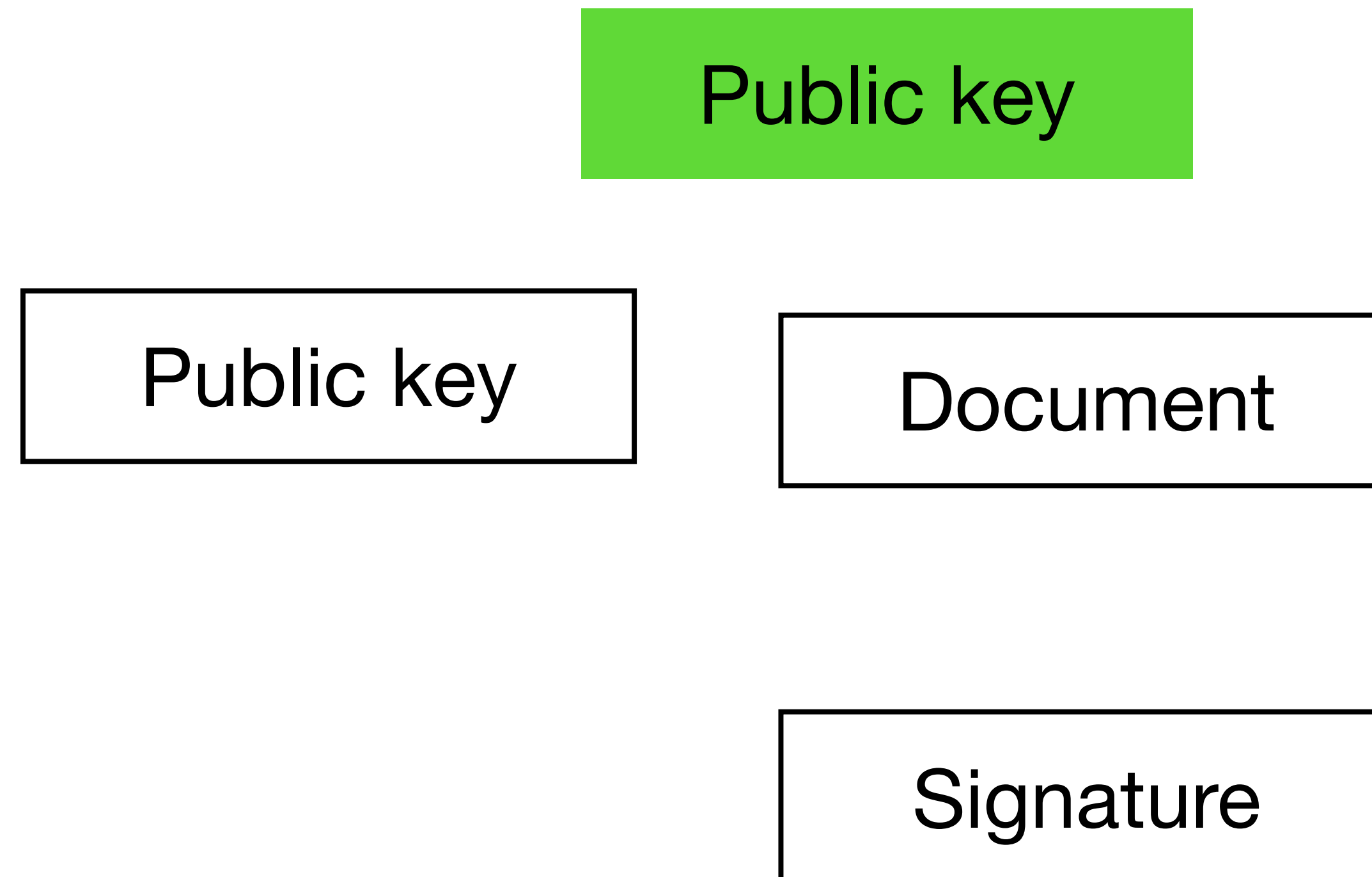
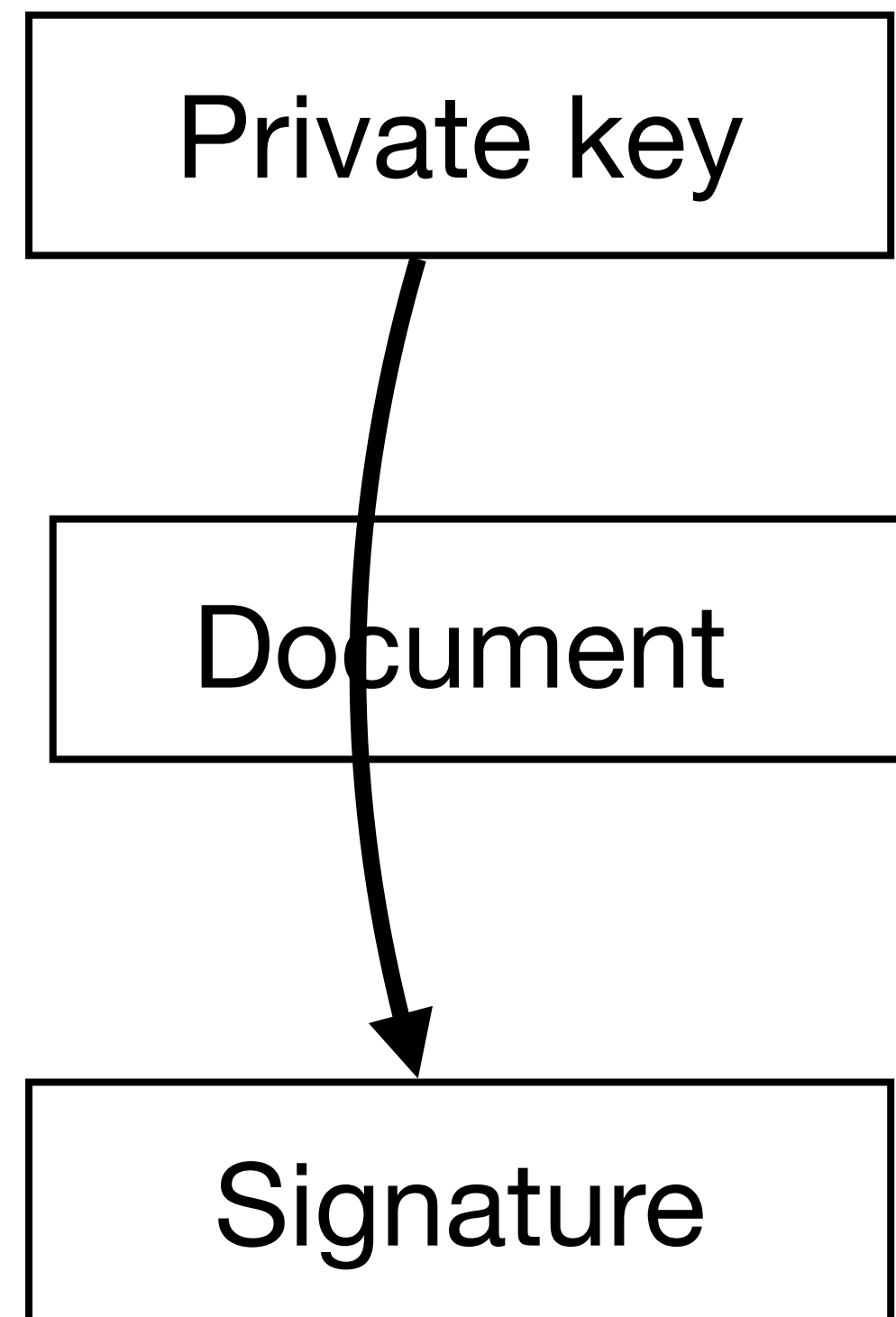


Začetna G



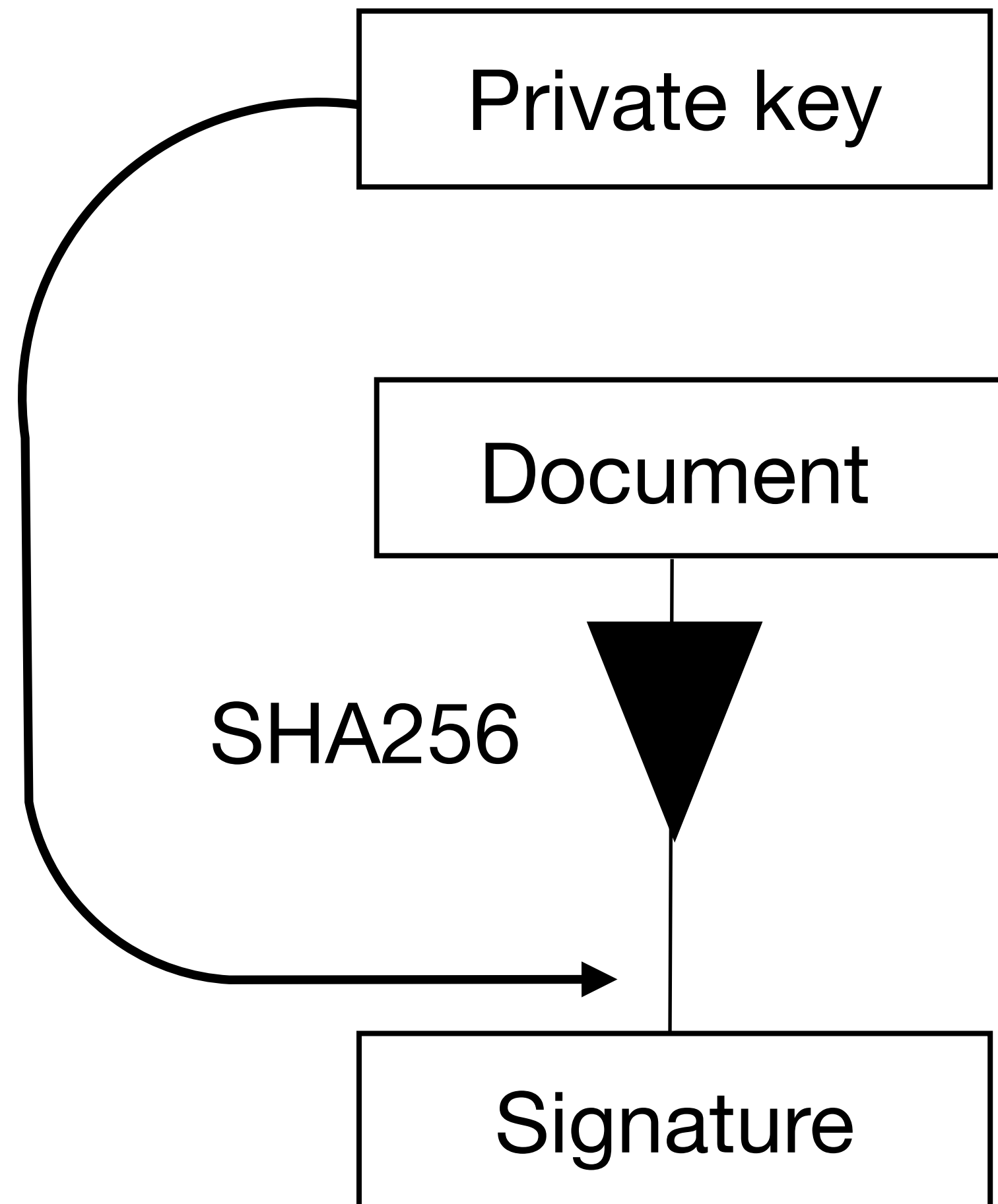
RSA zadnjič

Velikost



RSA zadnjič

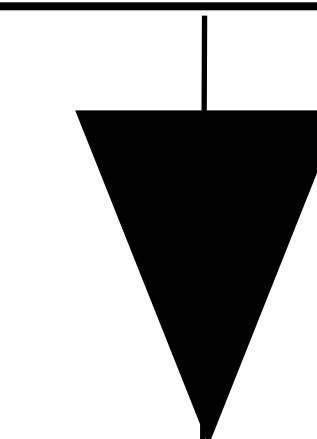
Velikost



Public key

Public key

Document



Verify

Signature